

Gerenciamento de Risco e Normas no Nível Tático

Objetivo da Aula

Compreender o gerenciamento de segurança da informação e seu impacto no mundo empresarial atual, onde a dependência da tecnologia e da informação continua a crescer, e entender que, no nível tático, as normas desempenham um papel fundamental na tradução das estratégias de segurança e no estabelecimento de políticas e práticas específicas.

Apresentação

O gerenciamento de segurança da informação é um elemento crítico nas operações e estratégias de uma organização. Para a proteção eficaz de seus ativos de informação e a minimização de riscos, é essencial que as práticas de gerenciamento de segurança sejam implantadas em vários níveis de operação.

Esta aula se concentra no nível tático, que atua como uma ponte crucial entre as estratégias definidas no nível estratégico e as operações diárias no nível operacional. Durante a implementação de medidas de segurança, a interpretação das normas desempenha um papel vital no nível tático, traduzindo-as em políticas, procedimentos e práticas específicas. Além disso, a identificação de ativos de informação e ameaças, a avaliação de riscos, a análise de vulnerabilidades e a seleção de controles apropriados são tarefas essenciais nesse processo.

À medida que a organização enfrenta ameaças crescentes, o gerenciamento de riscos é imperativo para proteger ativos críticos e garantir a conformidade legal e regulatória. Neste guia, exploraremos a importância do gerenciamento de riscos, os objetivos e benefícios associados, além das etapas envolvidas na identificação de ativos e ameaças, avaliação de riscos, análise de vulnerabilidades, e na implementação de medidas de mitigação e controle de riscos. Também abordaremos a necessidade de um ciclo de vida de risco contínuo e as diretrizes fornecidas por normas, como o ISO 27001. Finalmente, discutiremos a importância da documentação e da geração de relatórios para acompanhar o progresso e a eficácia das medidas de segurança no nível tático de uma organização.

1. Nível Tático

O nível tático é uma das camadas ou estágios de gerenciamento de uma organização, situando-se entre o nível estratégico e o nível operacional. No contexto de gerenciamento de segurança da informação, o nível tático desempenha um papel importante na implementação das estratégias definidas no nível estratégico e na coordenação das atividades operacionais.

Neste nível, as normas desempenham um papel fundamental. É aqui que as políticas são interpretadas e traduzidas em normas, procedimentos e práticas específicas que orientam as atividades diárias da organização. As equipes de gerenciamento de nível tático são responsáveis por garantir que a organização cumpra as normas e padrões relevantes. Eles também têm a responsabilidade de implementar controles e medidas de segurança para atender aos requisitos das normas.

Aqui estão algumas características e funções típicas do nível tático em uma organização:

- **Implementação das estratégias:**
 - O nível tático traduz as estratégias gerais estabelecidas no nível estratégico em planos de ação específicos. Ele se concentra na execução de projetos e iniciativas que ajudam a alcançar os objetivos estratégicos.
- **Coordenação departamental:**
 - Nesse nível, os gestores e líderes de departamentos ou unidades funcionais desempenham um papel-chave. Eles trabalham juntos para alinhar as atividades de suas áreas com os objetivos estratégicos da organização.
- **Tomada de decisão:**
 - As decisões tomadas no nível tático são mais detalhadas e específicas do que as decisões estratégicas de alto nível, mas ainda têm um impacto significativo na organização. Essas decisões orientam as operações diárias e projetos.
- **Controle e monitoramento:**
 - O nível tático é responsável por monitorar o desempenho e o progresso em relação aos objetivos estratégicos. Isso envolve a definição de indicadores-chave de desempenho (KPIs) e a análise de dados para avaliar o sucesso.
- **Alocação de recursos:**
 - Os recursos, como pessoal, orçamento e tecnologia, são alocados e gerenciados no nível tático para atender às necessidades das operações e projetos.

No contexto específico de segurança da informação, o nível tático é responsável por implementar medidas de segurança de acordo com as estratégias de segurança definidas no nível estratégico. Isso inclui a coordenação de iniciativas de segurança, a definição de normas e diretrizes, a seleção e implementação de controles de segurança, a análise de riscos e a supervisão das operações de segurança.

Em resumo, o nível tático é a camada intermediária de gerenciamento que conecta a alta direção da organização (nível estratégico) com as operações do dia a dia (nível operacional) e desempenha um papel fundamental na execução de estratégias e na garantia de que os objetivos organizacionais sejam alcançados de maneira eficaz.

2. Gerenciamento de Riscos

O Gerenciamento de Risco de Segurança da Informação é um componente fundamental da estratégia organizacional para proteger ativos de informação valiosos e sensíveis. Nesta seção introdutória, abordaremos a importância do gerenciamento de riscos em segurança da informação e destacamos os objetivos e benefícios associados a esse processo no nível tático de uma organização.

A segurança da informação desempenha um papel crítico no ambiente de negócios atual, em que as organizações dependem cada vez mais da tecnologia e da informação para operar e tomar decisões. No entanto, a expansão da tecnologia também traz consigo uma série de ameaças e vulnerabilidades que podem comprometer a confidencialidade, integridade e disponibilidade dos dados e sistemas. Dentro deste contexto, o gerenciamento de riscos em segurança da informação se torna imperativo frente aos seguintes motivos:

- **Proteção de ativos críticos:**

- As organizações armazenam informações críticas, como dados financeiros, informações de clientes, propriedade intelectual e segredos comerciais;
- O gerenciamento de riscos é essencial para proteger esses ativos contra ameaças.

- **Conformidade legal e regulatória:**

- Muitas indústrias e países têm regulamentações rígidas que exigem a proteção adequada das informações;
- O não cumprimento dessas regulamentações pode resultar em penalidades significativas.

- **Reputação da organização:**

- Incidentes de segurança da informação podem afetar seriamente a reputação de uma organização;
- A perda de confiança dos clientes e parceiros de negócios pode ter impactos financeiros e operacionais substanciais.

- **Prevenção de perdas financeiras:**

- A ocorrência de incidentes de segurança, como violações de dados, pode resultar em perdas financeiras diretas e indiretas, incluindo custos de recuperação, ações legais e perda de negócios.

2.1. Objetivos e Benefícios do Gerenciamento de Riscos no Nível Tático

O principal objetivo é identificar e compreender os riscos de segurança da informação que impactam a organização em seus níveis operacional e tático. Isso abrange ameaças, vulnerabilidades e ativos críticos. O gerenciamento de riscos busca, também, realizar avaliações detalhadas para determinar a probabilidade e o impacto de incidentes de segurança, auxiliando na priorização dos riscos com base em sua gravidade.

O estabelecimento de planos e medidas de mitigação para os riscos identificados, incluindo a seleção e implementação de controles de segurança adequados, também é um objetivo crucial. Além disso, o monitoramento contínuo do ambiente de segurança da informação e a aplicação de medidas corretivas quando necessário são essenciais para garantir a eficácia das políticas e controles de segurança.

O gerenciamento de riscos no nível tático contribui para a redução da exposição da organização a ameaças, minimizando a probabilidade e o impacto de incidentes de segurança. Viabiliza a conformidade com regulamentações e requisitos legais relacionados à segurança da informação, evitando as penalidades associadas. A base das decisões de segurança em dados concretos leva a uma alocação de recursos mais eficiente e a ações direcionadas. Isso, por sua vez, ajuda a proteger a reputação da organização ao evitar incidentes de segurança prejudiciais. Ao minimizar interrupções decorrentes de incidentes de segurança, o gerenciamento de riscos mantém a continuidade dos negócios e a eficiência operacional.

2.2. Identificação de Ativos e Ameaças em SegInfo

Os ativos de informação são elementos críticos para as operações e o sucesso de uma organização. Eles podem ser categorizados em diversas formas, incluindo dados, sistemas, hardware, software, pessoal, processos e documentação. É fundamental que a organização compreenda a natureza e o valor desses ativos.

Para identificar ativos de informação, é necessário realizar um inventário abrangente. Isso pode envolver:

- Colaboração com diversos departamentos e áreas para identificar os ativos sob sua responsabilidade;
- Documentação detalhada de cada ativo, incluindo sua localização, proprietário, valor, importância para as operações e nível de confidencialidade;
- Classificação dos ativos de acordo com seu valor crítico e sensibilidade, para priorizar a proteção.

Essa fase é fundamental para a compreensão da paisagem de ativos de informação da organização, o que por sua vez permitirá uma abordagem mais eficaz para a segurança da informação.

Uma vez que os ativos de informação tenham sido identificados, é crucial considerar as ameaças que podem afetá-los. As ameaças representam eventos ou condições que têm o potencial de causar danos aos ativos. Elas podem ser internas ou externas à organização e variam em natureza e origem.

Para identificar ameaças potenciais, é necessário:

- Avaliar o ambiente operacional da organização para identificar fontes potenciais de ameaças, como concorrentes, hackers, funcionários desonestos, desastres naturais, entre outros;
- Analisar tendências de segurança e incidentes passados para compreender os tipos de ameaças que outras organizações enfrentaram;
- Considerar cenários hipotéticos de ameaças que poderiam afetar os ativos, como ataques cibernéticos, vazamentos de dados, desastres ambientais, entre outros.

A identificação de ameaças é um processo contínuo, uma vez que o cenário de ameaças está em constante evolução. Compreender as ameaças potenciais permite que a organização tome medidas proativas para mitigar esses riscos.

É importante notar que a identificação de ativos e ameaças é o ponto de partida para o desenvolvimento de estratégias de segurança da informação. A partir desse ponto, as organizações podem avançar para a avaliação de riscos e a definição de medidas de mitigação adequadas para proteger seus ativos de informação eficazmente.

2.3. Avaliação de Riscos

A avaliação de riscos é um processo crítico no gerenciamento de segurança da informação, que visa identificar, analisar e quantificar os riscos potenciais que podem afetar os ativos de informação de uma organização. Existem duas abordagens principais para a avaliação de riscos: análise qualitativa e análise quantitativa.

- **Análise qualitativa de riscos:** é um método que se concentra em avaliar os riscos com base em qualidades, em vez de quantidades específicas. Nesse processo, os riscos são classificados e priorizados de acordo com critérios subjetivos, como a gravidade, a probabilidade e o impacto. Os riscos podem ser categorizados como baixo, médio ou alto, com base na avaliação desses critérios. Essa abordagem é frequentemente utilizada quando dados quantitativos detalhados não estão disponíveis ou são difíceis de obter.
- **Análise quantitativa de riscos:** é uma abordagem mais precisa e baseada em números. Ela envolve a atribuição de valores numéricos aos riscos, incluindo probabilidade e impacto. Métricas e modelos estatísticos são frequentemente usados para calcular a probabilidade de ocorrência de um evento de risco e seu impacto financeiro. Isso resulta em uma avaliação quantitativa do risco, expressa em termos de valores monetários ou outras unidades mensuráveis. A análise quantitativa é particularmente útil quando se trata de riscos financeiros, pois permite a alocação de recursos com base em dados objetivos.

Métricas e critérios desempenham um papel fundamental na determinação da gravidade dos riscos. Essas medidas fornecem uma base objetiva para avaliar o impacto potencial de um risco e sua probabilidade de ocorrência. A gravidade de um risco é determinada através da combinação de métricas como:

- **Probabilidade:** a probabilidade de um evento de risco ocorrer é quantificada, muitas vezes em uma escala de 0 a 1 (ou 0% a 100%);
- **Impacto:** o impacto do evento é avaliado em termos financeiros, operacionais ou em qualquer unidade relevante para a organização;
- **Exposição ao Risco:** a exposição ao risco é calculada multiplicando a probabilidade pelo impacto, proporcionando uma medida da gravidade do risco;
- **CrITÉrios de Priorização:** a organização define critérios específicos para classificar os riscos, como categorização em “baixo”, “médio” ou “alto”, com base nas métricas de probabilidade e impacto.

Essas métricas e critérios ajudam a hierarquizar os riscos, permitindo à organização concentrar seus recursos na mitigação dos riscos de maior gravidade que podem ter um impacto significativo nos objetivos e operações.

2.4. Análise de Vulnerabilidade

A análise de vulnerabilidades é um pilar essencial da avaliação de riscos em segurança da informação, desempenhando um papel vital na identificação de fragilidades e pontos de exposição nos ativos de informação de uma organização. Esse processo visa fornecer *insights* valiosos sobre como proteger ativos críticos contra ameaças potenciais. Vamos explorar como a análise de vulnerabilidades é realizada.

A primeira etapa da análise de vulnerabilidades envolve a minuciosa identificação de pontos fracos em diversos aspectos, como sistemas, aplicativos, redes, procedimentos e até mesmo no comportamento humano, que possam ser explorados por ameaças para comprometer a segurança dos ativos de informação. Essas vulnerabilidades podem ser de natureza técnica, como falhas de software, ou não técnica, como políticas de segurança inadequadas. A identificação é um processo abrangente e detalhado que requer uma visão holística dos ativos e suas interações no ambiente.

Também é necessário realizar testes de segurança, como varreduras de vulnerabilidades, testes de penetração e avaliações de segurança, é uma parte crítica do processo de identificação de vulnerabilidades. Esses testes buscam ativamente por falhas e fraquezas em sistemas e aplicativos, expondo possíveis vulnerabilidades que podem ser exploradas por ameaças.

Uma vez que as vulnerabilidades tenham sido identificadas, a análise prossegue com a consideração de como as ameaças podem explorá-las. Isso envolve a avaliação da probabilidade de ocorrência de um evento de risco e a compreensão do impacto caso esse evento ocorra, levando em consideração as vulnerabilidades previamente identificadas. As ameaças podem ser diversas em natureza, incluindo ataques cibernéticos, desastres naturais, ações de pessoal mal-intencionado, entre outros. A análise de vulnerabilidades é uma etapa fundamental para entender como as vulnerabilidades podem ser exploradas em diferentes cenários de ameaças.

2.5. Medidas de Mitigação e Controle de Riscos

No âmbito da gestão de segurança da informação, a mitigação e controle de riscos desempenham um papel fundamental na garantia da proteção eficiente dos ativos de

informação da organização. A seguir, discutiremos estratégias e princípios relevantes para essa etapa crucial do processo.

As medidas de mitigação de riscos visam reduzir a probabilidade de ocorrência e o impacto de eventos de risco. Isso é alcançado por meio da implementação de controles de segurança, que consistem em práticas, políticas, procedimentos, tecnologias e salvaguardas projetadas para minimizar vulnerabilidades e ameaças. Esses controles têm o propósito de fortalecer a segurança dos ativos de informação, tornando mais desafiante para ameaças explorarem as vulnerabilidades identificadas.

A seleção de controles apropriados é uma tarefa crítica e depende da avaliação de riscos realizada anteriormente. A organização deve considerar fatores como a gravidade dos riscos, os recursos disponíveis, as melhores práticas do setor e os requisitos regulatórios. A escolha dos controles deve estar alinhada com os objetivos de segurança da organização e garantir que os recursos sejam direcionados de maneira eficaz para áreas de maior vulnerabilidade.

2.6. Ciclo de Vida do Risco

O gerenciamento de riscos não é um evento isolado, mas um processo contínuo e iterativo. Essa abordagem reconhece que o cenário de ameaças está em constante evolução, assim como os ativos e operações da organização. Portanto, é fundamental revisar e atualizar regularmente as avaliações de riscos.

Esse ciclo de vida do risco compreende diversas fases:

Figura 1: Ciclo de vida do risco



Fonte: Adaptação de ISO 27000. Disponível em: <http://www.iso27000.com.br/index.php/site-map/articles/78-ciclo-de-vida-de-um-incidente>. Acesso em: 2 fev. 2024.

- **Identificação de riscos:**

- Nessa etapa, os riscos são identificados e documentados, considerando os ativos, ameaças e vulnerabilidades. A organização procura entender os eventos que podem afetar seus ativos e operações.

- **Avaliação de riscos:**

- Uma vez identificados, os riscos são avaliados em termos de probabilidade e impacto. Isso permite priorizar os riscos com base em sua gravidade e probabilidade de ocorrência.

- **Mitigação e controle de riscos:**

- Com a avaliação em mãos, a organização implementa controles e medidas para reduzir a probabilidade e o impacto dos riscos identificados. Isso envolve a escolha, implementação e manutenção de controles de segurança apropriados.

- **Monitoramento e revisão:**

- O ambiente de segurança da informação é continuamente monitorado para garantir que os controles estejam funcionando eficazmente. A organização deve revisar regularmente as avaliações de riscos, levando em consideração novas ameaças, mudanças nos ativos e operações e lições aprendidas com incidentes de segurança.

- **Comunicação e documentação:**

- Durante todo o ciclo de vida do risco, a comunicação e documentação adequadas são essenciais. Isso envolve a comunicação de riscos e controles para partes interessadas relevantes e a manutenção de registros detalhados para referência futura.

- **Melhoria contínua:**

- Com base nas revisões e no aprendizado contínuo, a organização pode aprimorar suas estratégias de mitigação de riscos e adotar medidas proativas para enfrentar novas ameaças e desafios.

Entender que o gerenciamento de riscos é um processo iterativo, não estático, é fundamental para a proteção eficaz dos ativos de informação e para a adaptação às mudanças no cenário de segurança cibernética e às evoluções organizacionais. Isso permite que as organizações ajam proativamente na identificação e mitigação de riscos, mantendo um ambiente seguro e resiliente ao longo do tempo.

3. Gerenciamento de Conformidade e Relatórios em Segurança da Informação

Normas e padrões desempenham um papel fundamental na garantia da segurança da informação e na padronização de práticas de gerenciamento de riscos. Entre esses padrões, um dos mais amplamente reconhecidos é o ISO 27001. O ISO 27001 é um padrão internacional que fornece diretrizes abrangentes para estabelecer, implementar, manter e melhorar sistemas de gestão de segurança da informação (SGSI).

A aplicação de normas como o ISO 27001 no contexto do gerenciamento de riscos é valiosa, pois oferece um quadro estruturado para a avaliação de riscos, a seleção de controles de segurança apropriados e a gestão contínua da segurança da informação. Essas normas fornecem diretrizes detalhadas para ajudar as organizações a entenderem e tratar os riscos, garantindo que as práticas de segurança estejam alinhadas com os padrões globalmente aceitos.

A documentação é uma parte essencial do gerenciamento de riscos em segurança da informação. Todas as atividades relacionadas ao processo, incluindo identificação de riscos, avaliações, planos de mitigação e controles implementados, devem ser devidamente documentadas. A documentação fornece um registro claro de todas as ações tomadas, ajudando na rastreabilidade e na prestação de contas.

A documentação inclui não apenas os detalhes técnicos, mas também os registros de decisões, comunicações e revisões ao longo do ciclo de vida do risco. Isso não apenas suporta a gestão eficaz de riscos, mas também auxilia em auditorias internas e externas, bem como na conformidade com regulamentações e padrões.

Além disso, a criação de relatórios adequados é uma prática útil para acompanhar o progresso e a eficácia das medidas de mitigação. Esses relatórios podem abranger o desempenho dos controles de segurança, as tendências de ameaças, as vulnerabilidades identificadas e a revisão contínua das avaliações de riscos. Eles oferecem *insights* valiosos para a alta administração e partes interessadas sobre o status da segurança da informação e ajudam a orientar a tomada de decisões informadas.

Em resumo, a conformidade com normas e padrões em segurança da informação, como o ISO 27001, é um componente importante para estabelecer práticas sólidas de gerenciamento de riscos. A documentação adequada e a geração de relatórios eficazes são elementos essenciais para garantir a transparência, a prestação de contas e a eficácia das medidas de segurança implementadas.

Considerações Finais da Aula

O gerenciamento de segurança da informação desempenha um papel vital no mundo empresarial atual, onde a dependência da tecnologia e da informação continua a crescer. Proteger ativos críticos, garantir a conformidade legal e regulatória, manter a reputação da organização e prevenir perdas financeiras são apenas algumas das razões pelas quais o gerenciamento de riscos em segurança da informação é imperativo.

No nível tático, as normas desempenham um papel fundamental na tradução das estratégias de segurança e no estabelecimento de políticas e práticas específicas. A documentação adequada e a geração de relatórios eficazes são essenciais para rastrear e avaliar o progresso e a eficácia das medidas de segurança implementadas. Além disso, a compreensão de que o gerenciamento de riscos é um processo contínuo e iterativo é crucial para a adaptação às mudanças no cenário de ameaças e nas operações organizacionais. Ao implementar práticas de gerenciamento de segurança em várias camadas da organização, as empresas podem garantir que seus ativos de informação sejam protegidos de maneira eficaz e que permaneçam seguras em um ambiente de negócios em constante evolução.

Materiais Complementares

Artigo

REDHAT

2024, Red Hat.

O site apresenta a disciplina de gerenciamento de configuração, que é uma forma de se certificar de que o sistema funciona como o esperado, ainda que alterações sejam feitas com o passar do tempo.

Disponível em: <https://www.redhat.com/pt-br/topics/automation/what-is-configuration-management>. Acesso em: 1º dez. 2023.

Vídeo

LGPD e o papel do DPO dentro de uma organização

2024, Gran Faculdade.

Além da ISO 27000, as leis de proteção de dados trazem um novo horizonte para a segurança da informação. As professoras Elaine Schwab e Vanessa Sanches oferecem uma análise detalhada sobre o papel fundamental do Encarregado de Proteção de Dados (DPO) no contexto da Lei Geral de Proteção de Dados (LGPD), abordando as responsabilidades e as estratégias que o DPO deve implementar para garantir o cumprimento das regulamentações de privacidade de dados em uma organização.

Disponível em: <https://www.youtube.com/watch?v=dACr9ZEHJdU&t=64s>. Acesso em: 1º dez. 2023.

Referências

BENZ, K. H. **Alinhamento estratégico entre as políticas de segurança da informação e as estratégias e práticas adotadas na TI**: estudos de caso em instituições financeiras. Dissertação (mestrado) – Universidade Federal do Rio Grande do Sul, Escola de Administração, Programa de Pós-graduação em Administração, 2008. Disponível em: <https://lume.ufrgs.br/handle/10183/12905>. Acesso em: 16 ago. 2023.

INTRODUÇÃO ao gerenciamento de TI. **Red Hat**, 2023. Disponível em: <https://www.redhat.com/pt-br/topics/management>. Acesso em: 14 ago. 2023.

PLANEJAMENTO estratégico em tecnologia da informação: um estudo sobre as dificuldades para implantação em uma instituição de ensino superior. **IBICT**, 2016. Disponível em: https://bdtd.ibict.br/vufind/Record/UFBA-2_14506dd17acf9e65bb57551ef4230ee2. Acesso em: 16 ago. 2023.